



АКАДЕМИЯ
КОДЕБАЙ

ПРОФЕССИЯ ПЕНТЕСТЕР

Всем доброго времени суток!

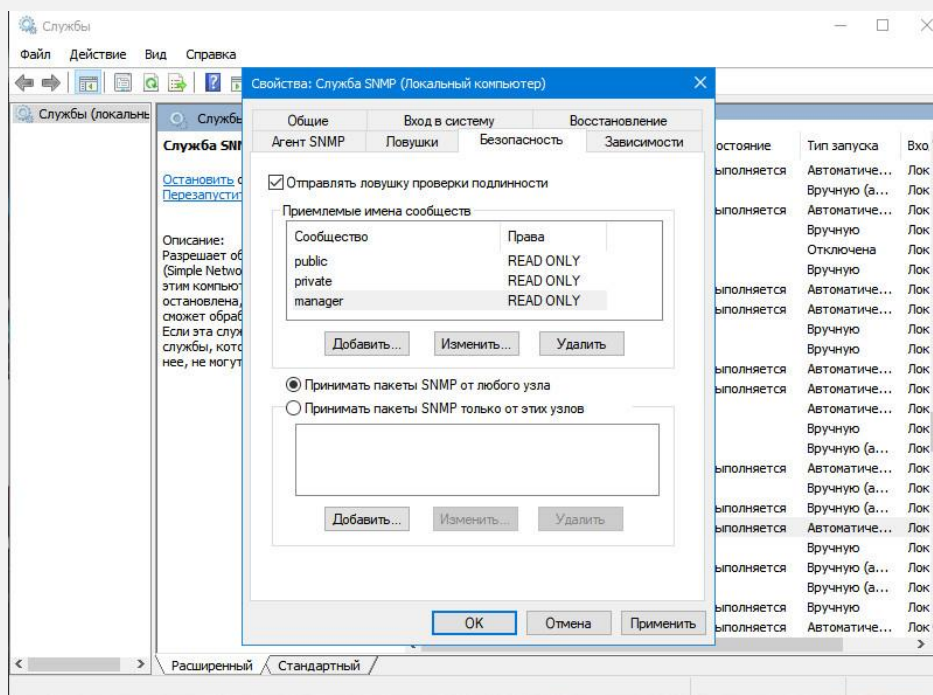
На протяжении многих лет мы часто сталкивались с тем, что простой протокол сетевого управления ([SNMP](#)) не очень хорошо понимается многими сетевыми администраторами. Это часто приводит к неправильной конфигурации SNMP, что может привести к значительной утечке информации.

SNMP основан на UDP, простом протоколе и подвержен атакам [IP-спуфинга](#) и [атакам повторного воспроизведения](#). Кроме того, широко используемые протоколы SNMP 1, 2 и 2с не предусматривают шифрования трафика, что означает, что информация SNMP и учетные данные могут быть легко перехвачены в локальной сети различными [снифферами](#) (анализаторами трафика). Теперь подумайте, что все вышесказанное относится к протоколу, который по определению предназначен для управления сетью. По всем этим причинам SNMP является еще одним из наших любимых протоколов перечисления.

Подготовка к уроку

Включение SNMP в Windows 10:

1. Заходим в "Панель управления".
2. Находим "Программы и компоненты".
3. В открывшемся окне слева в списке переходим по ссылке "Включение или отключение компонентов Windows".
4. В списке ищем строчку "SNMP-протокол" — отмечаем галочкой — Нажимаем "ОК".
5. Переходим в Службы (Панель управления — Администрирование — Службы) где выбираем среди всех служб "Служба SNMP" и запускаем.
6. Переходим на вкладку "Безопасность" — отмечаем галочкой "Отправлять ловушку проверки подлинности" и добавляем три имени сообщества - "public", "private" и "manager" с правами "READ ONLY".



7. "Применить" — "OK".

Дерево SNMP MIB

База SNMP Management Information Base (MIB) - это база данных, содержащая информацию, обычно относящуюся к управлению сетью. База данных организована как дерево, где ветви представляют различные организации или сетевые функции. Листья дерева (конечные точки) соответствуют конкретным значениям переменных, к которым внешний пользователь может получить доступ и исследовать их. В Интернете мы можем найти множество информации о дереве MIB.

Например, следующие значения MIB соответствуют конкретным параметрам Microsoft Windows SNMP и содержат гораздо больше информации, чем сетевая информация:

1.3.6.1.2.1.25.1.6.0 System Processes (Системные процессы)

1.3.6.1.2.1.25.4.2.1.2 Running Programs (Запущенные программы)

1.3.6.1.4.1.77.1.2.25 User Accounts (Учетные записи пользователей)

и т.д.

Сканирование SNMP

Для сканирования открытых портов SNMP мы можем запустить Nmap, как показано в следующем примере. Опция `-sU` используется для выполнения сканирования UDP, а опция `--open` - для вывода только открытых портов:

```
kali@kali:~$ sudo nmap -sU --open -p 161 192.168.0.1-254 -oG open-snmp.txt
```

```
(kali@kali)-[~]  
$ sudo nmap -sU --open -p 161 192.168.0.1-254 -oG open-snmp.txt  
Starting Nmap 7.92 ( https://nmap.org ) at 2022-08-09 09:34 EDT  
Nmap scan report for 192.168.0.174  
Host is up (0.0045s latency).  
  
PORT      STATE      SERVICE  
161/udp   open|filtered snmp  
MAC Address: 4C:CC:6A:27:6B:FB (Micro-star Intl)  
  
Nmap done: 254 IP addresses (5 hosts up) scanned in 4.57 seconds
```

В качестве альтернативы можно использовать такой инструмент, как `onesixtyone`, который попытается провести атаку брутфорс на список IP-адресов. Сначала мы должны создать текстовые файлы, содержащие строки сообщества и IP-адреса, которые мы хотим просканировать:

```
kali@kali:~$ echo public > community  
kali@kali:~$ echo private >> community  
kali@kali:~$ echo manager >> community  
kali@kali:~$ for ip in $(seq 1 254); do echo 192.168.0.$ip; done > ipaddress  
kali@kali:~$ onesixtyone -c community -i ipaddress
```

```
(kali@kali)-[~]  
$ echo public > community  
  
(kali@kali)-[~]  
$ echo private >> community  
  
(kali@kali)-[~]  
$ echo manager >> community  
  
(kali@kali)-[~]  
$ for ip in $(seq 1 254); do echo 192.168.0.$ip; done > ipaddress
```

```
(kali@kali)-[~]  
$ onesixtyone -c community -i ipaddress  
Scanning 254 hosts, 4 communities  
192.168.0.174 [public] Hardware: Intel64 Family 6 Model 60 Stepping 3 AT/AT C  
OMPATIBLE - Software: Windows Version 6.3 (Build 15063 Multiprocessor Free)  
192.168.0.174 [private] Hardware: Intel64 Family 6 Model 60 Stepping 3 AT/AT  
COMPATIBLE - Software: Windows Version 6.3 (Build 15063 Multiprocessor Free)  
192.168.0.174 [manager] Hardware: Intel64 Family 6 Model 60 Stepping 3 AT/AT  
COMPATIBLE - Software: Windows Version 6.3 (Build 15063 Multiprocessor Free)
```

Соответственно, как только мы находим службы SNMP, мы можем начинать запрашивать у них конкретные данные MIB, которые нам могут быть интересны.

Пример перечисления SNMP в Windows

Мы можем исследовать и запрашивать значения SNMP с помощью такого инструмента, как `snmpwalk`, при условии, что мы, по крайней мере, знаем строку сообщества SNMP только для чтения ("READ ONLY"), которая в большинстве случаев является "public".

Перечисление всего дерева MIB

Используя некоторые значения MIB, представленные ранее, мы можем попытаться перечислить их соответствующие значения. Давайте попробуем выполнить следующие команды к машине, которая имеет открытый порт Windows SNMP, со строкой сообщества "public". Эта команда перечисляет все дерево MIB, используя опцию `-c` для указания строки сообщества, и `-v` для того, чтобы указать номер версии SNMP, а также параметр `-t 10`, чтобы увеличить период тайм-аута до 10 секунд:

```
kali@kali:~$ snmpwalk -c public -v1 -t 10 192.168.0.174
```

```
(kali@kali)-[~]  
$ snmpwalk -c public -v1 -t 10 192.168.0.174  
iso.3.6.1.2.1.1.1.0 = STRING: "Hardware: Intel64 Family 6 Model 60 Stepping 3  
AT/AT COMPATIBLE - Software: Windows Version 6.3 (Build 15063 Multiprocessor  
Free)"  
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.311.1.1.3.1.1  
iso.3.6.1.2.1.1.3.0 = Timeticks: (414946) 1:09:09.46  
iso.3.6.1.2.1.1.4.0 = ""  
iso.3.6.1.2.1.1.5.0 = STRING: "DESKTOP-JA7CNCQ"  
iso.3.6.1.2.1.1.6.0 = ""  
iso.3.6.1.2.1.1.7.0 = INTEGER: 76  
iso.3.6.1.2.1.2.1.0 = INTEGER: 40  
iso.3.6.1.2.1.2.2.1.1 = INTEGER: 1  
iso.3.6.1.2.1.2.2.1.2 = INTEGER: 2  
iso.3.6.1.2.1.2.2.1.3 = INTEGER: 3  
iso.3.6.1.2.1.2.2.1.4 = INTEGER: 4  
iso.3.6.1.2.1.2.2.1.5 = INTEGER: 5  
iso.3.6.1.2.1.2.2.1.6 = INTEGER: 6  
iso.3.6.1.2.1.2.2.1.7 = INTEGER: 7  
iso.3.6.1.2.1.2.2.1.8 = INTEGER: 8
```

Перечисление пользователей Windows

```
kali@kali:~$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.4.1.77.1.2.25
```

```
(kali@kali)-[~]  
$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.4.1.77.1.2.25 130 x  
iso.3.6.1.4.1.77.1.2.25.1.1.5.65.68.77.73.78 = STRING: "ADMIN"  
iso.3.6.1.4.1.77.1.2.25.1.1.10.208.147.208.190.209.129.209.130.209.140 = Hex-  
STRING: D0 93 D0 BE D1 81 D1 82 D1 8C  
iso.3.6.1.4.1.77.1.2.25.1.1.14.68.101.102.97.117.108.116.65.99.99.111.117.110  
.116 = STRING: "DefaultAccount"  
iso.3.6.1.4.1.77.1.2.25.1.1.26.208.144.208.180.208.188.208.184.208.189.208.18  
4.209.129.209.130.209.128.208.176.209.130.208.190.209.128 = Hex-STRING: D0 90  
D0 B4 D0 BC D0 B8 D0 BD D0 B8 D1 81 D1 82  
D1 80 D0 B0 D1 82 D0 BE D1 80
```

Перечисление запущенных процессов Windows

```
kali@kali:~$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.2.1.25.4.2.1.2
```

```
(kali@kali)-[~]  
$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.2.1.25.4.2.1.2  
iso.3.6.1.2.1.25.4.2.1.2.1 = STRING: "System Idle Process"  
iso.3.6.1.2.1.25.4.2.1.2.4 = STRING: "System"  
iso.3.6.1.2.1.25.4.2.1.2.436 = STRING: "smss.exe"  
iso.3.6.1.2.1.25.4.2.1.2.460 = STRING: "svchost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.484 = STRING: "svchost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.492 = STRING: "fontdrvhost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.560 = STRING: "conhost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.656 = STRING: "fontdrvhost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.672 = STRING: "csrss.exe"  
iso.3.6.1.2.1.25.4.2.1.2.676 = STRING: "svchost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.764 = STRING: "csrss.exe"  
iso.3.6.1.2.1.25.4.2.1.2.788 = STRING: "wininit.exe"  
iso.3.6.1.2.1.25.4.2.1.2.868 = STRING: "winlogon.exe"  
iso.3.6.1.2.1.25.4.2.1.2.916 = STRING: "services.exe"  
iso.3.6.1.2.1.25.4.2.1.2.948 = STRING: "lsass.exe"  
iso.3.6.1.2.1.25.4.2.1.2.968 = STRING: "hasplmv.exe"  
iso.3.6.1.2.1.25.4.2.1.2.1032 = STRING: "svchost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.1056 = STRING: "chrome.exe"  
iso.3.6.1.2.1.25.4.2.1.2.1088 = STRING: "svchost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.1144 = STRING: "dwm.exe"  
iso.3.6.1.2.1.25.4.2.1.2.1260 = STRING: "svchost.exe"  
iso.3.6.1.2.1.25.4.2.1.2.1300 = STRING: "unsecapp.exe"
```

Перечисление открытых портов TCP

```
kali@kali:~$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.2.1.6.13.1.3
```

```
(kali@kali)-[~]  
$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.2.1.6.13.1.3  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.21.0.0.0.0 = INTEGER: 21  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.80.0.0.0.0 = INTEGER: 80  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.135.0.0.0.0 = INTEGER: 135  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.445.0.0.0.0 = INTEGER: 445  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.902.0.0.0.0 = INTEGER: 902  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.912.0.0.0.0 = INTEGER: 912  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1433.0.0.0.0 = INTEGER: 1433  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1536.0.0.0.0 = INTEGER: 1536  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1537.0.0.0.0 = INTEGER: 1537  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1538.0.0.0.0 = INTEGER: 1538  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1539.0.0.0.0 = INTEGER: 1539  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1540.0.0.0.0 = INTEGER: 1540  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1550.0.0.0.0 = INTEGER: 1550  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1688.0.0.0.0 = INTEGER: 1688  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.1947.0.0.0.0 = INTEGER: 1947  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.2383.0.0.0.0 = INTEGER: 2383  
iso.3.6.1.2.1.6.13.1.3.0.0.0.0.7070.0.0.0.0 = INTEGER: 7070  
iso.3.6.1.2.1.6.13.1.3.127.0.0.1.1434.0.0.0.0 = INTEGER: 1434  
iso.3.6.1.2.1.6.13.1.3.127.0.0.1.1544.127.0.0.1.5354 = INTEGER: 1544  
iso.3.6.1.2.1.6.13.1.3.127.0.0.1.1545.127.0.0.1.5354 = INTEGER: 1545  
iso.3.6.1.2.1.6.13.1.3.127.0.0.1.2095.127.0.0.1.65001 = INTEGER: 2095
```

Перечисление установленного программного обеспечения

```
kali@kali:~$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.2.1.25.6.3.1.2
```

```
iso.3.6.1.2.1.25.6.3.1.2.5 = STRING: "Burp Suite Community Edition 2021.6.2"  
iso.3.6.1.2.1.25.6.3.1.2.6 = STRING: "AVG AntiVirus FREE"  
iso.3.6.1.2.1.25.6.3.1.2.7 = STRING: "CCleaner"  
iso.3.6.1.2.1.25.6.3.1.2.8 = STRING: "DAEMON Tools Lite"  
iso.3.6.1.2.1.25.6.3.1.2.9 = STRING: "FabFilter Total bundle 1.0.0.2 (Repack)"  
"  
iso.3.6.1.2.1.25.6.3.1.2.10 = STRING: "HeidiSQL"  
iso.3.6.1.2.1.25.6.3.1.2.11 = STRING: "HxD Hex Editor 2.5"  
iso.3.6.1.2.1.25.6.3.1.2.12 = STRING: "IDA Freeware and Hex-Rays Decompilers  
(x64) 7.6"  
iso.3.6.1.2.1.25.6.3.1.2.13 = Hex-STRING: CF E0 EA E5 F2 20 EE E1 ED EE E2 EB  
E5 ED E8 FF  
20 33 20 E4 EB FF 20 53 51 4C 20 53 65 72 76 65  
72 20 32 30 38 20 52 32 20 28 4B 42 32 39 37  
39 35 39 37 29 20 28 36 34 2D 62 69 74 29  
iso.3.6.1.2.1.25.6.3.1.2.14 = STRING: "Loaris Trojan Remover 3.0.97"
```

Команды, используемые в уроке:

```
kali@kali:~$ sudo nmap -sU --open -p 161 192.168.0.1-254 -oG open-snmp.txt
```

```
kali@kali:~$ echo public > community
```

```
kali@kali:~$ echo private >> community
```

```
kali@kali:~$ echo manager >> community
```

```
kali@kali:~$ for ip in $(seq 1 254); do echo 192.168.0.$ip; done > ipaddress
```

```
kali@kali:~$ onesixtyone -c community -i ipaddress
```

```
kali@kali:~$ snmpwalk -c public -v1 -t 10 192.168.0.174
```

```
kali@kali:~$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.4.1.77.1.2.25
```

```
kali@kali:~$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.2.1.25.4.2.1.2
```

```
kali@kali:~$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.2.1.6.13.1.3
```

```
kali@kali:~$ snmpwalk -c public -v1 192.168.0.174 1.3.6.1.2.1.25.6.3.1.2
```